Incident Response Policy

Policy Number: 02/Y2025

Version: 1.0

Effective Date: 07. December.2025

Owner: Governance, Risk and Compliance (GRC) Manager

Approved by: Board of Directors

1. Purpose and Scope

1.1. Purpose

This policy establishes the framework for TechMed Solutions to prepare for, detect, respond to, and recover from security incidents. The goal is to minimize the impact of incidents, protect sensitive data (including PHI and PCI data), maintain business continuity, and comply with all legal and regulatory requirements.

1.2. Scope

This policy applies to all TechMed Solutions employees, contractors, third-party service providers, and anyone with access to TechMed Solutions' information systems and data. It covers all information assets, including hardware, software, data, and network infrastructure, whether on-premises or in the cloud.

2. Definitions

Term	Definition
Security Event	Any observable occurrence in a system or network.
Security Incident	A violation or imminent threat of violation of computer security policies, acceptable use policies, or standard security practices.
Incident Response	The systematic approach to addressing and managing the aftermath of a security breach or cyberattack.
Incident Severity Levels	Tiered categories that describe the likelihood and the impact and dictate the urgency of a security incident. They provide a standard way to determine response priorities, required actions, and escalation path.
Computer Security Incident Response Team (CSIRT)	A dedicated team of individuals responsible for coordinating and executing the incident response plan.

Protected Health Information (PHI)	Individually identifiable health information that is transmitted or maintained in any form or medium.
Payment Card Industry (PCI) Data	Cardholder data and sensitive authentication data.

3. Roles and Responsibilities

Role	Responsibilities
Executive Leadership (CEO, Board)	Provide overall strategic direction, approve the incident response policy, and allocate necessary resources.
Chief Information Security Officer (CISO)	Oversee the incident response program, chair the CSIRT, and make critical decisions during an incident.
GRC Manager	Develop and maintain the incident response policy and plan, ensure compliance with regulatory requirements, and coordinate post-incident reviews.
IT Operations	Provide technical support during an incident, including system access, network changes, and data restoration.
Legal Counsel	Provide guidance on legal and regulatory obligations, including breach notification requirements.
Human Resources	Manage any employee-related aspects of an incident, including insider threats and disciplinary actions.
Communications	Manage all internal and external communications during an incident.
All Employees	Report any suspected security incidents immediately and cooperate with the CSIRT during an investigation.

4. Incident Classification Framework

4.1. Incident Types

Type	Description
Malware	Ransomware, viruses, worms, Trojans, spyware.
Unauthorized Access	Access to systems or data by an unauthorized individual.
Data Breach	Confirmed exfiltration of sensitive data.
Denial of Service (DoS)	An attack that prevents legitimate users from accessing a service.
Insider Threat	A malicious or unintentional act by an employee, contractor, or other insider.
Physical Security	Theft or loss of equipment, unauthorized access to facilities.

4.2. Incident Severity Levels

Severity	Criteria
Critical	Widespread impact, critical systems affected, significant data loss or exfiltration of PHI/PCI data, major business disruption, high likelihood of regulatory action.

High	Significant impact, multiple systems or departments affected, potential for data loss of sensitive data, moderate business disruption.
Medium	Localized impact, single system or small group of users affected, minimal data loss, minor business disruption.
Low	Minor impact, no critical systems affected, no data loss, no business disruption.

5. Reporting Requirements

All employees and contractors are required to report any suspected security incidents immediately.

- **Reporting Channel:** Our main channel for notification is the IT Helpdesk and escalation to the GRC Manager via email where the channel is unreachable. In case of an emergency and If all channels are unreachable call the ICT Head or GRC Manager.
- **Timeframe:** Immediately upon discovery (for both Suspected and Conformed)
- **Escalation Path:** The IT Help Desk will escalate all suspected security incidents to the CSIRT for triage and validation.

6. Regulatory and Legal Compliance

TechMed Solutions is committed to complying with all applicable laws and regulations, including:

- **HIPAA:** The Health Insurance Portability and Accountability Act.
- **PCI DSS:** The Payment Card Industry Data Security Standard.
- **GDPR:** The General Data Protection Regulation.
- **State Breach Notification Laws:** EU and US State Breach Notification Laws

All incident response activities will be conducted in a manner that preserves evidence for potential legal action and complies with all breach notification requirements.

7. Policy Review and Updates

This policy will be reviewed and updated at least annually, or more frequently if there are significant changes to the threat landscape, regulatory requirements, or business operations. The GRC Manager is responsible for coordinating the review and update process.